

AUDITORÍA TÉCNICA Y FUNCIONAL DE EVALUHR

Revisión para análisis jurídico y de cumplimiento bajo legislación mexicana
(LFPDPPP, NOM-035-STPS-2018, Art. 37 Bis)

Base de evidencia: Código fuente en /home/z/my-project

Alcance: 22 rutas API · 16 modelos Prisma · 4 plantillas de evaluación

Verificabilidad: Cada afirmación incluye archivo y línea citable

Fecha: 2025-07-25

Commit base: 1249353

Documento: Confidencial — para revisión jurídica

AUDITORÍA TÉCNICA Y FUNCIONAL DE EVALUHR

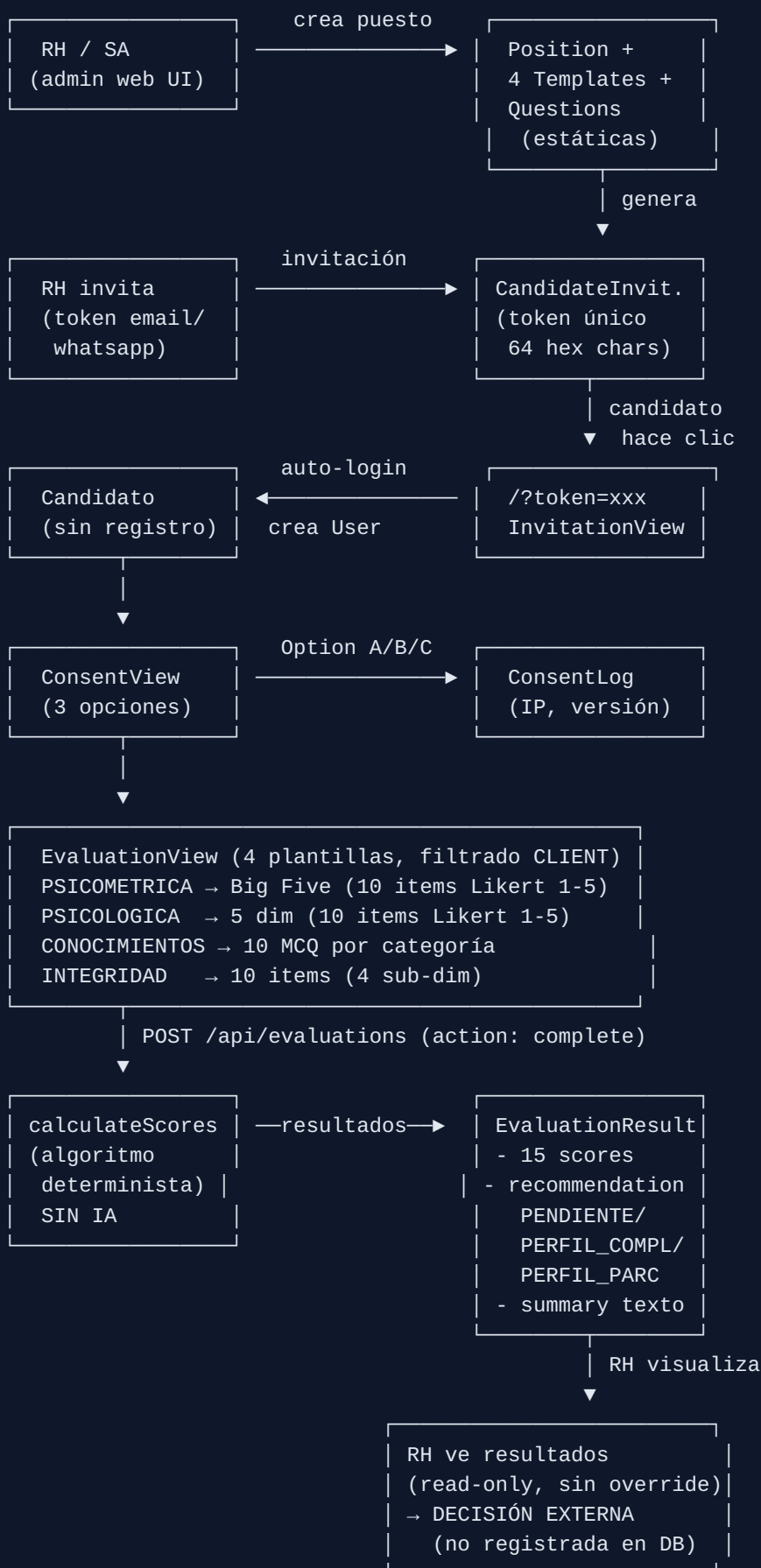
Base de evidencia: Código fuente en `/home/z/my-project` (revisión directa, no especulativa) **Alcance:** 22 rutas API, 16 modelos Prisma, 4 plantillas de evaluación, middleware, auth, RLS, consentimiento, privacidad
Verificabilidad: Cada afirmación incluye archivo y línea citable **Fecha:** 2025-07-25 **Destino:** Revisión jurídica y de cumplimiento bajo legislación mexicana (LFPDPPP, NOM-035-STPS-2018, Art. 37 Bis)

RESUMEN EJECUTIVO

- 1. EvaluHR es una plataforma web** (Next.js 16 + Prisma + Supabase Postgres) que aplica 4 pruebas psicométricas/psicológicas/de conocimientos/de integridad a candidatos invitados por empresas.
IMPLEMENTADO Y COMPROBADO
- 2. No utiliza IA en producción.** La dependencia `z-ai-web-dev-sdk` está declarada en `package.json:84` pero **no se importa ni se invoca en ningún archivo de `src/`**. La documentación `PROJECT_STATUS.md` menciona una ruta `/api/vacancies/[id]/generate-questions` que **no existe en el código actual**.
IMPLEMENTADO Y COMPROBADO (ausencia verificada)
- 3. Las 4 pruebas usan preguntas redactadas por el desarrollador**, NO adaptadas de instrumentos validados. El “Big Five” se menciona como nombre descriptivo del modelo, sin citar IPIP, NEO-PI-R, BFI, Maslach, IRI, Reid, Hogan ni ningún instrumento normado. **NO IMPLEMENTADO (referencias a validación)**
- 4. Las fórmulas de scoring fueron creadas por el desarrollador** (`/api/evaluations/route.ts:10-217`). Normalización lineal $((avg-1)/4)*100$ para Likert 1-5. Pesos adaptativos del overall score (8 combinaciones) sin justificación psicométrica documentada. **IMPLEMENTADO Y COMPROBADO (fórmulas propias)**
- 5. El concepto “APTO/NO_APTO” fue eliminado** del código en producción (`src/`). Persiste solo en `prisma/seed.ts:907,978` y `scripts/seed-supabase.ts:340,418,444` como datos semilla obsoletos. El campo `recommendation` ahora produce `PENDIENTE | PERFIL_COMPLETO | PERFIL_PARCIAL` (orientación de completitud, no decisión de contratación). **IMPLEMENTADO Y COMPROBADO (eliminación)**
- 6. No existe auto-exclusión algorítmica.** Ningún `WHERE` por score o `recommendation` en `/api/candidates` o `/api/results`. Comentarios explícitos: “orientative, never auto-filter” (`route.ts:112`), “never as disqualification (LFPDPPP Art. 37 Bis)” (`route.ts:271`). **IMPLEMENTADO Y COMPROBADO**
- 7. No existe override manual** del `recommendation` o `overallScore` por RRHH. `/api/results` solo soporta GET. RRHH no puede modificar resultados algorítmicos. **IMPLEMENTADO Y COMPROBADO**
- 8. No existe decisión final registrada en el sistema.** No hay campo “contratado/no contratado”, no hay `decisionById`, `decisionAt`, `decisionReason` en ningún modelo. La decisión final es 100% externa al sistema. **NO IMPLEMENTADO**
- 9. Option B (KNOWLEDGE_ONLY) NO se cumple técnicamente.** El filtrado solo existe client-side (`EvaluationView.tsx:58-66`). El servidor `/api/evaluations` POST **nunca verifica `consentOption`** antes de aceptar respuestas a preguntas sensibles. Un candidato con consent B puede vía API directa responder items PSICOMETRICA y se almacenarán. **CRÍTICO — NO IMPLEMENTADO server-side**

10. **Option C (estadísticas anónimas) NO está implementada.** Solo se guarda un booleano `anonymousStats` en `User`. No existe pipeline de anonimización ni endpoint de estadísticas agregadas. La cadena `EvaluationResponse → Session.candidateId → User.id` permite reidentificación trivial. **NO IMPLEMENTADO**
 11. **Derechos ARCO NO están implementados como workflow.** Solo son menciones textuales en la UI y el aviso de privacidad. No hay endpoints de auto-servicio para candidatos. El contacto es por email manual a `recursos.humanos@cafedechiapas.mx` con SLA de 20 días hábiles (solo textual). **NO IMPLEMENTADO**
 12. **El flujo de revocación miente.** La UI dice “Sus respuestas serán marcadas para eliminación” (`EvaluationView.tsx:912-938`), pero `/api/consent` PATCH solo cambia `consentOption` a `KNOWLEDGE_ONLY` y marca `consentWithdrawnAt`. **No elimina ninguna respuesta sensible.** No hay job programado de eliminación. **CRÍTICO — IMPLEMENTADO PARCIALMENTE (misrepresentación)**
 13. **Existe un endpoint de fabricación retroactiva de consentimiento** (`/api/consent/fix`, accesible por RH/GERENTE/SUPER_ADMIN) que crea registros `consentGiven=true` después de completada la evaluación, con `consentVersion: 'retroactive-fix'`. **VIOLACIÓN LFPDPPP Art. 8 (consentimiento debe ser previo, expreso e informado).** **CRÍTICO — IMPLEMENTADO PERO ILEGAL**
 14. **Credenciales hardcodeadas en git:** `service_role` JWT de Supabase (expira 2036) en `scripts/seed-supabase-clean.mjs:9`; contraseña DB `9042mgt0993` en `scripts/apply-supabase-schema.mjs:12`; fallback `JWT_SECRET='fallback-dev-secret-change-in-production'` en `src/lib/auth.ts:3-5` y `src/middleware.ts:4-6`. **CRÍTICO — EXPOSICIÓN**
 15. **RLS a nivel DB está definido pero NO aplicado.** Solo RLS a nivel app (Prisma extension) funciona. `getUnscopedClient()` se usa en **41 ubicaciones de 14 archivos**, bypassando todo RLS. `/api/health` es público y expone email del SUPER_ADMIN, prefijo de `JWT_SECRET` y conteos. **CRÍTICO — IMPLEMENTADO PARCIALMENTE**
-

ARQUITECTURA DEL SISTEMA



Flujo verificado en código: Empresa → crea puesto (4 plantillas estáticas) → invita candidato → candidato auto-login → consentimiento → evaluación → scoring algorítmico → **EvaluationResult** con orientación (NO decisión) → RH visualiza → **decisión laboral ocurre fuera del sistema.**

PRUEBAS

Prueba	Instrumento	Preguntas	Fórmula	IA	Validación	Riesgo
PSICOMETRICA (Big Five)	"Big Five" (nombre descriptivo, sin citar IPIP/NEO/BFI)	10 (2 por dimensión: O,C,E,A,N)	$((\text{avgLikert}-1)/4)*100$; NEUROTICISM con reverse-scoring en items	NO	NO IMPLEMENTADO — items originales, sin baremos, 2 items/dim insuficiente para $\alpha \geq .70$	ALTO
PSICOLOGICA	Ninguno citado	10 (2 por dimensión: stress, empathy, adaptability, leadership, teamwork)	$((\text{avg}-1)/4)*100$; STRESS con 100-normalized post-normalización (además de reverse en items → doble inversión)	NO	NO IMPLEMENTADO — items originales, no Maslach/IRI/LPI	ALTO
CONOCIMIENTOS	Original (90 preguntas: 9 categorías × 10)	10 por categoría	$(\text{correctas}/\text{total})*100$, sin umbral aprobatorio	NO	N/A (conocimiento técnico, no psicométrico)	BAJO
INTEGRIDAD	"Overt integrity test" original (estructura HONESTY/RULES/THEFT/RESPONSIBILITY)	10 (5 reverse-scored)	$((\text{avg}-1)/4)*100$, marcado "orientativo, never auto-filter"	NO	NO IMPLEMENTADO — no Reid/HD-29/Hogan; items 7-8 elicitan auto-incriminación de robo	ALTO

Clasificación A/B/C/D (pregunta 2):

- **A) Instrumentos validados respetando reglas:** NO APLICA
- **B) Adaptaciones de instrumentos existentes:** NO APLICA
- **C) Preguntas nuevas inspiradas en instrumentos:** **PARCIAL** — los items de Big Five y STRESS son paráfrasis vagas de items IPIP/PSS pero no verificables como adaptaciones formales
- **D) Metodología propia combinada:** **APLICA** a las 4 pruebas — fórmulas y items son originales del desarrollador

Estado: IMPLEMENTADO PARCIALMENTE — Las pruebas existen y funcionan técnicamente, pero **no constituyen instrumentos psicométricos validados.**

IA

NO SE ENCONTRÓ USO DE IA EN EL CÓDIGO DE PRODUCCIÓN.**Evidencia verificada:**

Pregunta	Respuesta	Evidencia
¿Qué modelos de IA se utilizan?	NINGUNO	Grep <code>z-ai-web-dev-sdk</code> en <code>src/</code> = 0 matches de import
¿La IA genera preguntas?	NO	<code>generate-templates.ts</code> define constantes literales JS
¿La IA modifica preguntas?	NO	CRUD manual en <code>/api/questions</code>
¿La IA interpreta respuestas?	NO	<code>calculateScores</code> (<code>route.ts:10-217</code>) es algorítmico puro
¿La IA genera recomendaciones?	NO	<code>guidance</code> se asigna por if/else determinista
¿La IA determina APTO?	NO	"APTO" no existe en <code>src/</code>
¿Decisions automatizadas?	NO	Summary generado por concatenación de strings hardcoded
¿Respuestas enviadas a proveedor externo?	NO	0 llamadas <code>fetch</code> salientes en <code>/api/**</code>
¿Consentimiento específico para IA?	N/A	No hay IA; aviso de privacidad no menciona IA

Dependencia huérfana: `z-ai-web-dev-sdk@^0.0.18` en `package.json:84` instalada pero **nunca importada**. Riesgo latente: existe la capacidad técnica de activarla.

Documentación inconsistente: `PROJECT_STATUS.md:645` describe una ruta `/api/vacancies/[id]/generate-questions` con IA que **no existe** en `src/app/api/`. Comentario en `src/app/api/positions/route.ts:202-206` confirma que fue removida.

Estado: IMPLEMENTADO Y COMPROBADO (ausencia total de IA verificada).

MOTOR DE PUNTUACIÓN

Archivo único: `/home/z/my-project/src/app/api/evaluations/route.ts:10-217`

Helpers base (líneas 10-21)

```
calculateLikertScore(value, reverseScored):
  v = clamp(1, 5, value)
  return reverseScored ? 6 - v : v

normalizeBigFive(avgScore)      = ((avg - 1) / 4) * 100
normalizePsychological(avgScore) = ((avg - 1) / 4) * 100  // idéntica a Big Five
```

Big Five (líneas 54-71)

- Promedio aritmético de items por dimensión → normalización lineal → clamp 0-100
- NEUROTICISM: reverse-scoring aplicado **solo a nivel item** (2 items marcados `reverseScored: true`)
- La UI vuelve a invertir neuroticism (`CandidateDetailView.tsx:96` : `100 - result.neuroticism`) — doble inversión vs servidor, posible bug

Psicológica (líneas 73-96)

- STRESS: reverse-scoring en items (2 items) + **inversión post-normalización** `100 - normalized` → **doble inversión** (divergente con NEUROTICISM que solo se invierte una vez)

Knowledge (líneas 98-110)

- `(correctas / total) * 100` , sin umbral aprobatorio

Integridad (líneas 117-131)

- `((avg-1)/4)*100` sin inversión post-normalización

Overall score — Pesos adaptativos (líneas 133-182)

BigFive	Psico	Integridad	Knowledge	Pesos
SI	SI	SI	SI	0.25 / 0.25 / 0.15 / 0.35 (knowledge)
SI	SI	SI	NO	0.30 / 0.30 / 0.40 / —
SI	SI	NO	SI	0.30 / 0.30 / — / 0.40
subset			SI	0.50 × behavioral + 0.50 × knowledge
subset sin knowledge			NO	promedio simple
1 sola sección	—	—	—	score directo

Origen de pesos: Definidos por el desarrollador. **No hay referencia a literatura psicométrica** que justifique 0.35 para knowledge o 0.15 para integridad.

Estado de fórmulas: IMPLEMENTADO Y COMPROBADO — fórmulas propias del desarrollador, NO son las oficiales de ningún instrumento (porque ningún instrumento validado está referenciado).

APTO / NO APTO

NO EXISTE EN EL CÓDIGO DE PRODUCCIÓN.

Búsqueda exhaustiva en `src/`: 0 coincidencias funcionales de `APTO`, `NO_APTO`, `APROBADO`, `REPROBADO`.

Persistencia residual (datos semilla obsoletos): - `prisma/seed.ts:907` → `recommendation: 'APTO'` - `prisma/seed.ts:943` → `recommendation: 'ENTREVISTA_ADICIONAL'` - `prisma/seed.ts:978` → `recommendation: 'NO_RECOMENDADO'` - `scripts/seed-supabase.ts:340, 418, 444` → mismos valores obsoletos

Comportamiento actual (`route.ts:188-195`):

```
if (sectionsWithData.length === 0) guidance = 'PENDIENTE'
else if (hasBigFive && hasPsych && hasIntegrity && knowledge !== null)
  guidance = 'PERFIL_COMPLETO'
else guidance = 'PERFIL_PARCIAL'
```

Pregunta	Respuesta
¿Condiciones para APTO?	N/A — concepto eliminado
¿Condiciones para NO APTO?	N/A — concepto eliminado
¿Quién definió las condiciones?	Desarrollador (commit <code>7b21c4d</code> y anteriores)
¿Configurables?	NO — hardcoded en <code>route.ts</code>
¿Diferentes por puesto?	NO — misma lógica para todos
¿Genera exclusión automática?	NO — <code>/api/candidates</code> no filtra por recommendation
¿Puede pasar a entrevista con PERFIL_PARCIAL?	SÍ — el sistema no impide nada
¿Empresa puede sobrescribir?	NO — <code>/api/results</code> solo GET
¿Queda registro de decisión?	NO — no hay <code>decisionById</code> / <code>decisionAt</code>

Estado: IMPLEMENTADO Y COMPROBADO (eliminación completa en `src/`). Persiste en datos semilla obsoletos — IMPLEMENTADO PARCIALMENTE.

RECOMENDACIÓN PARA ENTREVISTA

NO EXISTE LÓGICA DE “RECOMENDADO PARA ENTREVISTA” EN PRODUCCIÓN.

El campo `recommendation` existe por compatibilidad DB pero **ya no es una recomendación de contratación**. Es una etiqueta de completitud (`PERFIL_COMPLETO` / `PERFIL_PARCIAL` / `PENDIENTE`).

Comentario explícito (`route.ts:211`): > `recommendation: guidance, // Keep field name for DB compatibility, but value is now guidance`

Cierre obligatorio en summary (route.ts:321): > “Esta evaluación proporciona orientación informativa. La decisión final corresponde al área de Recursos Humanos.”

Pregunta	Respuesta
¿Variables que intervienen?	Solo completitud de secciones, NO scores
¿Umbrales?	NINGUNO — sin cutoff
¿Automático?	Sí, pero produce orientación no decisión
¿Obligatorio?	No — RH puede ignorar
¿RRHH puede ignorar?	SÍ (no hay enforcement)
¿Puede excluir a alguien?	NO — sin WHERE por recommendation
¿Genera ranking?	NO — sin ORDER BY por score en <code>/api/candidates</code>
¿Intervención humana?	Obligatoria pero no registrada — no hay <code>decisionById</code>
¿Candidato → algoritmo → no recomendado → excluido sin humano?	NO POSIBLE — no existe “no recomendado”

Estado: IMPLEMENTADO Y COMPROBADO — el sistema **no puede producir** el flujo `candidato → algoritmo → excluido` porque no hay categoría de exclusión.

DECISIÓN HUMANA

Pregunta	Respuesta	Estado
¿RRHH debe revisar el resultado?	No es obligatorio técnicamente	PARCIAL
¿RRHH puede decidir distinto a la “recomendación”?	Sí (no hay recommendation real)	COMPROBADO
¿Existe botón “contratar/no continuar”?	NO	NO IMPLEMENTADO
¿Existe justificación de la decisión?	NO	NO IMPLEMENTADO
¿Se registra quién tomó la decisión?	NO — no hay <code>decisionById</code>	NO IMPLEMENTADO
¿Se registra cuándo?	NO	NO IMPLEMENTADO
¿Se registra el motivo?	NO	NO IMPLEMENTADO
¿Sistema distingue recomendación algorítmica vs decisión humana?	NO	NO IMPLEMENTADO
¿Sistema puede excluir automáticamente?	NO	COMPROBADO

Flujo real: 1. Candidato completa evaluación → se almacena `EvaluationResult` (solo scores + orientación) 2. RH ve resultados en `CandidateDetailView` (read-only) 3. RH toma decisión **fuera del sistema** (email, llamada, hoja de cálculo) 4. **No queda rastro en DB de la decisión laboral**

Estado: IMPLEMENTADO PARCIALMENTE — la decisión humana ocurre pero es **invisible al sistema**. No hay trazabilidad de la decisión final.

DATOS PERSONALES

Dato	Almacenamiento	Período	Acceso	Modifica	Elimina
Nombre completo	User.name , CandidateInvitation.candidateName , EvaluationResult.candidateName , VacancyApplication.candidateName	Indefinido (2 años declarados, no enforced)	SA, RH (own co.), GERENTE (own co.)	RH/SA vía / api/users	SA vía /api/ candidates DELETE (también borra ConsentLog)
Email	User.email (unique), CandidateInvitation.email , VacancyApplication.candidateEmail	Indefinido	SA, RH, GERENTE	RH/SA	SA DELETE
Teléfono	User.phone? , CandidateInvitation.phone? , VacancyApplication.candidatePhone?	Indefinido	SA, RH, GERENTE	RH/SA	SA DELETE
Edad	VacancyApplication.candidateAge Int?	Indefinido	SA, RH, GERENTE	N/A	SA DELETE
Password (hash bcrypt 12 rounds)	User.password	Indefinido	Solo verificación	/api/users PATCH	SA DELETE
Empresa	User.companyId , User.companyName	Indefinido	SA, RH	SA	SA DELETE
Rol	User.role	Indefinido	SA, RH	SA vía /api/ users	SA DELETE
Estado de consentimiento	User.consentGiven , consentDate , consentOption , anonymousStats , consentConfirmed , consentWithdrawnAt , consentVersion	Indefinido	SA, RH	RH/SA /api/ consent PATCH	SA DELETE
IP de consentimiento	ConsentLog.ipAddress	Indefinido (aviso declara 90 días — no enforced)	SA	NO	SA DELETE (borra evidencia)
Respuestas a tests (crudo)	EvaluationResponse.value , EvaluationResponse.numericValue	Indefinido (aviso dice “eliminados al concluir” — MENTIRA)	SA, RH, GERENTE (own co.)	NO editable	SA DELETE
Scores (15 floats)	EvaluationResult.openness , conscientiousness , ..., integrityScore , overallScore	Indefinido	SA, RH, GERENTE	NO editable	SA DELETE
Recommendation	EvaluationResult.recommendation	Indefinido	SA, RH, GERENTE	NO editable	SA DELETE
Summary textual	EvaluationResult.summary	Indefinido	SA, RH, GERENTE	NO	SA DELETE
Sesión de evaluación	EvaluationSession.status , startedAt , completedAt	Indefinido	SA, RH	NO	SA DELETE

Dato	Almacenamiento	Período	Acceso	Modifica	Elimina
Invitación	<code>CandidateInvitation.token</code> , <code>status</code> , <code>channel</code> , <code>expiresAt</code>	Indefinido	SA, RH	NO	SA DELETE
Entrevistas	<code>InterviewSchedule.scheduledAt</code> , <code>location</code> , <code>notes</code> , <code>status</code>	Indefinido	SA, RH, GERENTE	RH/SA <code>/api/ interviews</code>	SA DELETE
CV / documentos	NO ALMACENADOS	N/A	N/A	N/A	N/A
Video	<code>VacancyApplication.videoUrl</code> declarado pero NUNCA escrito/leído en <code>src/</code>	N/A	N/A	N/A	N/A
IP de login	NO ALMACENADA	N/A	N/A	N/A	N/A
User-Agent	NO ALMACENADO (excepto consentimiento que tampoco)	N/A	N/A	N/A	N/A
Dispositivo / fingerprint	NO ALMACENADO	N/A	N/A	N/A	N/A
Logs de auditoría	Solo <code>console.log</code> en stdout (no persistente)	Efímero	N/A	N/A	N/A
Fotografías	NO ALMACENADAS	N/A	N/A	N/A	N/A
Aviso de privacidad (texto)	<code>CompanyPrivacyNotice.contentHtml</code>	Indefinido	SA, RH	RH/SA <code>/api/ privacy- notice</code> PUT	Overwrite (no historial)

DATOS SENSIBLES

Conforme LFPDPPP Art. 9 (datos personales sensibles):

Categoría sensible	¿EvaluHR la revela?	Evidencia
Origen étnico	NO	Ningún ítem pregunta
Religión	NO	Ningún ítem pregunta
Opiniones políticas	NO	Ningún ítem pregunta
Afiliación sindical	NO	Ningún ítem pregunta
Orientación/preferencia sexual	NO	Ningún ítem pregunta
Salud física	NO directo	Ningún ítem clínico
Salud mental / estado psicológico	PARCIAL	Big Five NEUROTICISM items 9-10 ("Me estreso fácilmente", "Me cuesta controlar mis emociones") y PSICOLOGICA STRESS items 1-2 ("abrumado con múltiples tareas", "cuesta desconectar del trabajo") elicitán estado emocional. No son instrumentos clínicos pero producen datos de estado psicológico.
Información genética	NO	Ningún ítem
Biometría	NO	Ningún ítem
Discapacidad	NO	Ningún ítem
Datos de personalidad (OCEAN)	SI	<code>EvaluationResult.openness</code> , <code>conscientiousness</code> , <code>extraversion</code> , <code>agreeableness</code> , <code>neuroticism</code> — explícitamente LFPDPPP Art. 7-I
Datos psicológicos (competencias)	SI	<code>stressLevel</code> , <code>empathy</code> , <code>adaptability</code> , <code>leadership</code> , <code>teamwork</code> — LFPDPPP Art. 7-II
Datos de integridad (conducta)	SI	<code>integrityScore</code> + 10 ítems que indagan comportamientos de honestidad/robo — Art. 7-V
Auto-incriminación de robo	CRÍTICO	Ítems 7 y 8 de INTEGRIDAD: "Considero que tomar pequeños artículos del trabajo sin permiso es aceptable si son de bajo valor" y "He utilizado recursos de la empresa para fines personales sin autorización". Podrían constituir datos sensibles por auto-incriminación de conducta ilícita .

Estado: IMPLEMENTADO PARCIALMENTE — se procesan 3 categorías explícitamente sensibles (personalidad, psicológico, integridad). **No hay categorías expresamente protegidas (religión, política, etc.) pero los ítems de integridad 7-8 requieren revisión legal.**

CONSENTIMIENTO

Pantalla que ve el candidato (`ConsentView.tsx`)

Elemento	Obligatorio	Estado
Opción A — Evaluación Completa (radio card)	Sí (A o B requeridos)	IMPLEMENTADO
Opción B — Solo Conocimientos (radio card)	Sí	IMPLEMENTADO
Opción C — Estadísticas Anónimas (checkbox independiente)	No	IMPLEMENTADO
Checkbox “He leído y comprendo las 3 opciones + ARCO”	Sí	IMPLEMENTADO
Botón “No consiento” / Rechazar	N/A	NO EXISTE — candidato en callejón sin salida

Body enviado a API (`ConsentView.tsx:85-91`)

```
{ userId, consentOption, anonymousStats, confirmedReading: true }
```

Almacenado en DB (`User` schema:45-51)

Campo	Capturado
<code>consentGiven</code>	SI
<code>consentDate</code>	SI timestamp
<code>consentOption</code>	SI FULL / KNOWLEDGE_ONLY
<code>anonymousStats</code>	SI boolean
<code>consentConfirmed</code>	SI
<code>consentWithdrawnAt</code>	SI (al retirar)
<code>consentVersion</code>	'2026-01-v1' (mismatch con notice '2026-01-v2')

ConsentLog (audit trail — schema:77-89)

Campo	Capturado
<code>userId</code>	SI
<code>action</code> (GIVEN/WITHDRAWN/MODIFIED)	SI
<code>previousOption</code> , <code>newOption</code>	SI
<code>anonymousStats</code>	SI
<code>consentVersion</code>	SI
<code>ipAddress</code>	SI (<code>x-forwarded-for</code> / <code>x-real-ip</code>)
<code>userAgent</code>	NO CAPTURADO
Hash del texto del aviso	NO CAPTURADO
Geo (país desde IP)	NO
<code>createdAt</code>	SI

Revocación (`/api/consent` PATCH, `route.ts:281-387`)

- **Botón visible:** “Retirar consentimiento de datos sensibles” (`EvaluationView.tsx:876-893`) — solo si `consentOption === 'FULL'`
- **UI promete:** “Sus respuestas serán marcadas para eliminación” (`EvaluationView.tsx:912-938`)
- **API hace:** Solo `consentOption → KNOWLEDGE_ONLY` , marca `consentWithdrawnAt` . **NO elimina ninguna respuesta.** Comentario explícito (`route.ts:277-280`): “We don’t delete the sensitive responses immediately, but flag the consent as withdrawn.”
- **No existe job programado de eliminación posterior.**

Versión y re-consentimiento

- `consentVersion` se almacena pero **NO se compara** con la versión actual al hacer login. Si el aviso cambia, candidatos antiguos **NO son forzados a re-consentir**.

Retroactividad — `/api/consent/fix` (CRÍTICO)

Endpoint accesible por RH/GERENTE/SUPER_ADMIN que **crea registros `consentGiven=true` después de completada la evaluación**, con `consentVersion: 'retroactive-fix'` (`route.ts:80`). Respuesta del API admite: “Este consentimiento fue registrado retroactivamente por un administrador.”

VIOLACIÓN LFPDPPP Art. 8 — consentimiento para datos sensibles debe ser **previo, expreso e informado**.

Estado: IMPLEMENTADO PARCIALMENTE — existe flujo de consentimiento, pero con gaps críticos: sin server-side enforcement, sin eliminación real al retirar, sin re-consentimiento al cambiar versión, con fabricación retroactiva ilegal.

ARCO

NO IMPLEMENTADO como workflow. Solo menciones textuales.

Derecho	Endpoint	UI candidato	Workflow admin	Estado
Acceso	Ninguno	Sin UI de exportación propia	Sin UI admin	NO IMPLEMENTADO
Rectificación	Ninguno (solo admin vía <code>/api/users</code>)	Sin self-service	RH puede editar manualmente	NO IMPLEMENTADO
Cancelación	<code>/api/candidates</code> DELETE requiere SA/RH/GERENTE	Sin botón candidato	SA/RH puede borrar	NO IMPLEMENTADO (candidato no puede autogestionarse)
Oposición	Ninguno	Ninguno	Ninguno	NO IMPLEMENTADO

Workflow real

- **Quién recibe:** Email `recursos.humanos@cafedechiapas.mx` (hardcoded en `ConsentView.tsx:207,432` y `EvaluationCompleteView.tsx:155`)
- **Quién procesa:** Manual, por humano de RRHH
- **SLA:** 20 días hábiles (declarado en aviso, **no enforced** por sistema)
- **Seguimiento:** Ninguno — no hay tabla `ArcoRequest`, no hay estados, no hay tickets
- **Auditoría de ARCO:** Ninguna

Eliminación efectiva

- `/api/candidates` DELETE (`route.ts:302-390`) ejecuta cascade raw SQL
- **Destruye `ConsentLog`** junto con el candidato (`route.ts:347, 381-383`) — **destruye evidencia de consentimiento**, violando Art. 88 del Reglamento LFPDPPP (retención de evidencia)
- No hay backups separados; no hay anonimización; no hay “soft-delete”

Email inconsistente

- UI (`ConsentView.tsx:207`): `recursos.humanos@cafedechiapas.mx`
- Aviso dinámico (`privacy-notice.ts:33-38`): `rrhh@<empresa-slug>.com`
- **Mails diferentes** según la pantalla que vea el candidato

Estado: NO IMPLEMENTADO — los derechos ARCO son solo declaraciones en aviso y UI, sin respaldo técnico.

CONSERVACIÓN

Tipo de dato	Período declarado en aviso	Período REAL en código	¿Auto-eliminación?
Datos personales (nombre, email, teléfono)	2 años post-evaluación (<code>privacy-notice.ts:572-584</code>)	INDEFINIDO	NO
Respuestas sensibles (psicométricas, psicológicas, integridad)	“Eliminados al concluir proceso o al retirar consentimiento” (<code>:589-608</code>)	INDEFINIDO — <code>EvaluationResponse</code> persiste siempre	NO
Datos de conocimientos	2 años	INDEFINIDO	NO
Resultados (scores)	2 años	INDEFINIDO	NO
Consent logs	No declarado	INDEFINIDO	NO
Logs de acceso / auditoría	No declarado	EFÍMERO (stdout, no persistente)	N/A
IP	90 días (<code>privacy-notice.ts:813-828</code>)	INDEFINIDO en <code>ConsentLog.ipAddress</code>	NO
Estadísticas anónimas	Sin límite	NO EXISTEN (Option C es un checkbox vacío)	N/A
Backups	No declarado	Dependiente de Supabase (no gestionado por app)	N/A

Discrepancias aviso vs realidad (CRÍTICO):

Promesa del aviso	Realidad
“Datos sensibles eliminados al concluir proceso”	FALSO — persisten indefinidamente
“Cifrado en reposo” (<code>:627-628</code>)	FALSO — sin cifrado columnar en schema
“Eliminación inmediata al retirar consentimiento”	FALSO — no se elimina nada
“Opción B no recopila datos sensibles” (<code>:545-547</code>)	FALSO — servidor las acepta igual
“IP retenida 90 días”	FALSO — retenida indefinidamente
“20 días hábiles ARCO”	Solo textual, sin enforcement

Estado: IMPLEMENTADO PARCIALMENTE — existe campo `consentWithdrawnAt` pero **ninguna política de retención está implementada técnicamente**. El aviso de privacidad **describe un comportamiento que el código no cumple**.

SUPABASE

Arquitectura

- **Proveedor:** Supabase Postgres 17 (región `ca-central-1` , Canada Central)
- **Pooler:** `aws-0-ca-central-1.pooler.supabase.com:6543` (PgBouncer)
- **Conexión:** Prisma ORM 6.11.1 (NO se usa `@supabase/supabase-js` en runtime)
- **Auth de Supabase:** NO USADO (auth propia con JWT HS256)
- **Storage de Supabase:** NO USADO (no hay buckets)
- **Realtime:** NO USADO

RLS — Estado CRÍTICO

Capa	Estado	Evidencia
DB-level RLS (Postgres policies)	NO ACTIVADO	<code>/api/rls-audit</code> retorna <code>databaseLevel.enabled: false</code>
Archivo <code>prisma/rls-policies.sql</code> (437 líneas)	Definido pero NO aplicado	Sin <code>FORCE ROW LEVEL SECURITY</code> — owner bypassa
App-level RLS (Prisma extension)	Funciona	<code>src/lib/rls.ts:99-274</code>
<code>getUnscopedClient()</code> bypass	41 usos en 14 archivos	Auth, cleanup, consent, users, etc.

Conexión Prisma usa rol `postgres` (superuser con `BYPASSRLS`) — incluso si se aplicaran las políticas, serían bypassadas.

Multi-tenant isolation

- **App-level RLS** auto-inyecta `companyId` en `where` clauses para modelos tenant-scoped (`src/lib/rls.ts:108-271`)
- **SUPER_ADMIN** bypassa todo RLS (`rls.ts:310` , `:326-332`)
- **SUPER_ADMIN puede impersonar** tenant vía `?companyId=xxx` (`createSuperAdminRLSClient`)
- **Auditoría de impersonación:** Solo `console.log('[AUDIT] SA impersonating company', ...)` — no persistente, no tamper-evident

Roles DB

- **No hay roles Postgres** definidos (solo `postgres` superuser)
- **No hay GRANT / REVOKE** en archivos SQL
- Roles solo existen en app (`User.role` string: SUPER_ADMIN/RH/GERENTE/CANDIDATO)

Storage buckets

- **NO DEFINIDOS** — `supabase/config.toml:120-125` todos comentados
- Campo `VacancyApplication.videoUrl` declarado pero **nunca usado**

Backups

- Dependiente de Supabase managed backups (no gestionado por la app)
- No hay backup lógico propio

Acceso administrativo

- Supabase dashboard (proyecto `ulgrgxjryezkedruvhdb`) — fuera del control de la app
- `service_role` JWT hardcodeado en `scripts/seed-supabase-clean.mjs:9` (expira 2036) — **credencial expuesta en git**
- DB password `9042mgt0993` hardcodeado en `scripts/apply-supabase-schema.mjs:12` — **expuesta en git**

Vulnerabilidades de acceso cruzado

Vector	Verificado	Estado
Candidato A ve resultados de Candidato B	POSIBLE	<code>/api/results?resultId=X</code> no verifica <code>candidateId</code> ownership para CANDIDATO (solo companyId)
RH empresa A ve candidatos empresa B	Bloqueado	App-RLS filtra por <code>companyId</code>
SUPER_ADMIN ve todo	Por diseño	Bypassa RLS
Token invitation reusado cross-tenant	POSIBLE	<code>auth/route.ts:193-216</code> muta <code>companyId</code> de User existente si mismatch

Estado: IMPLEMENTADO PARCIALMENTE — la arquitectura funciona pero RLS DB está inactivo, hay 41 bypasses vía `getUnscopedClient()`, y existen 2 vulnerabilidades de escalación horizontal.

TERCEROS

Proveedor	Datos recibidos	Propósito	Almacenamiento	Opt-out entrenamiento	Contrato
Supabase (Postgres, ca-central-1, Canada)	TODOS los datos de la app (PII, sensible, scores)	DB hosting	Sí (es el almacenamiento principal)	N/A (no es IA)	NO DETERMINABLE (términos Supabase)
Vercel	Logs de requests (pueden incluir PII en URL params), variables de entorno	Hosting Next.js	Logs efímeros	N/A	NO DETERMINABLE
GitHub (repositorio)	Solo código (PERO credenciales hardcodeadas en <code>scripts/</code>)	Versionado	Persistente	N/A	NO DETERMINABLE
Proveedores de IA (OpenAI, Anthropic, etc.)	NINGUNO	N/A	N/A	N/A	N/A
Email/ WhatsApp (para invitaciones)	Solo envío (no gestionado por app)	Canal de invitación	La app no envía, solo genera link	N/A	N/A
Analytics	NINGUNO	N/A	N/A	N/A	N/A

Transferencias internacionales: - Aviso de privacidad §11 declara: “No se transfieren datos personales a terceros” (`privacy-notice.ts:388-408`) - **REALIDAD:** Supabase está en `ca-central-1` (Canada) y Vercel puede desplegar en múltiples regiones → **Sí hay transferencia internacional** a Canadá (y posiblemente USA si Vercel routing pasa por allá). El aviso **omite esto**.

Estado: IMPLEMENTADO PARCIALMENTE — el aviso declara “no transferencias” pero la realidad técnica sí las involucra (Supabase Canada, Vercel).

SEGURIDAD

Controles implementados

Control	Estado	Evidencia
HTTPS	SI Vercel enforced	Default Vercel
HSTS	NO IMPLEMENTADO	Sin headers config
Cifrado en tránsito	SI TLS	Default
Cifrado en reposo DB	SI Supabase managed	Default
Cifrado columnar sensible	NO IMPLEMENTADO	Aviso lo afirma falsamente (:627-628)
Password hashing	SI bcrypt 12 rounds	src/lib/password.ts:4
Legacy SHA-256	Migra a bcrypt on login	password.ts:31-33
JWT HS256 expira 8h	SI	auth.ts:7
Cookie httpOnly + secure + sameSite=lax	SI	auth/route.ts:122
Token en localStorage	DUPLICA httpOnly — XSS puede robarlo	store.ts:161
MFA	NO IMPLEMENTADO	Confirmado ausente
Account logout	NO IMPLEMENTADO	Sin failedAttempts counter
Password reset flow	NO IMPLEMENTADO	Solo admin vía /api/users PATCH
Rate limiting	NO IMPLEMENTADO en ninguna ruta	Sin paquetes
CSRF protection	Solo SameSite=Lax	Sin token CSRF
CORS config	No definido	Default same-origin
Security headers (CSP, X-Frame, etc.)	NO IMPLEMENTADO	Sin helmet, sin config
SQL injection	SI Prisma parameterized	Safe
XSS sanitization	NO IMPLEMENTADO	CompanyPrivacyNotice.contentHtml raw — stored XSS risk si RH inyecta <script>
File upload validation	N/A	No hay uploads
Session revocation list	NO	Token válido hasta expiración
Audit log (DB table)	NO	Solo console.log
JWT_SECRET fallback	CRÍTICO	'fallback-dev-secret-change-in-production' hardcodeado en auth.ts:3-5 y middleware.ts:4-6
Secrets en código	CRÍTICO	service_role + DB password en scripts/

Vulnerabilidades importantes

#	Vulnerabilidad	Severidad
V1	<code>JWT_SECRET</code> con fallback público → si env var falta, JWTs firmables por cualquiera	CRÍTICO
V2	<code>/api/health</code> público expone email <code>SUPER_ADMIN</code> + prefijo <code>JWT_SECRET</code> + conteos	CRÍTICO
V3	<code>/api/cleanup</code> destrucción multi-tenant irreversible sin auditoría ni confirmación	CRÍTICO
V4	service_role Supabase + DB password hardcodeados en <code>scripts/</code> committed a git	CRÍTICO
V5	Token JWT en localStorage — derrote httpOnly, habilita robo por XSS	ALTO
V6	Stored XSS vía <code>CompanyPrivacyNotice.contentHtml</code> sin sanitización	ALTO
V7	Sin rate limiting → brute-force <code>/api/auth</code> y enumeración de invitation tokens	ALTO
V8	Sin account lockout → unlimited password attempts	ALTO
V9	Sin security headers (HSTS, CSP, X-Frame-Options)	ALTO
V10	Escalación horizontal candidato → candidato vía <code>/api/results?resultId=</code>	MEDIO
V11	<code>/api/users</code> PUT sin verificar <code>companyId</code> cross-tenant para RH	ALTO
V12	Auto-login muta <code>companyId</code> si mismatch — token replay cross-tenant	MEDIO
V13	<code>/api/public/invitation</code> expone PII completa (nombre, email, teléfono) a cualquiera con el token	MEDIO
V14	Errores retornan <code>details: String(error)</code> → info disclosure	BAJO

Estado: IMPLEMENTADO PARCIALMENTE — controles básicos (bcrypt, JWT, httpOnly cookie) presentes, pero faltan controles críticos (rate limiting, MFA, account lockout, security headers, sanitización XSS, sesión revocation).

AUDITORÍA (Trazabilidad)

Evento	¿Registrado?	Dónde
Quién creó evaluación (puesto)	NO Solo <code>createdAt</code> , sin <code>createdBy</code>	<code>Position.createdAt</code>
Quién modificó puesto	NO Sin <code>updatedBy</code>	<code>Position.updatedAt</code> (solo timestamp)
Qué versión de plantilla se aplicó	PARCIAL Solo <code>consentVersion</code> en User, no en Template	<code>EvaluationTemplate</code> sin versionado
Qué preguntas recibió el candidato	SI Vía <code>EvaluationResponse.questionId</code>	DB
Qué fórmula se utilizó	NO REGISTRADO	Solo código estático
Qué resultado obtuvo	SI <code>EvaluationResult</code> scores	DB
Qué recommendation produjo sistema	SI <code>EvaluationResult.recommendation</code>	DB
Quién vio los resultados	NO REGISTRADO	Sin log de acceso lectura
Quién cambió una decisión	N/A — no hay decisión registrada	N/A
Cuándo ocurrió	PARCIAL Solo <code>createdAt</code> / <code>updatedAt</code>	Sin <code>decisionAt</code>
Motivo del cambio	NO REGISTRADO	N/A
Consentimiento otorgado	SI <code>ConsentLog</code> con IP, timestamp, versión	DB
Consentimiento retirado	SI <code>ConsentLog.action: 'WITHDRAWN'</code>	DB
Login de usuario	NO REGISTRADO	Sin login log
SUPER_ADMIN impersonando tenant	PARCIAL Solo <code>console.log</code> efímero	stdout
Acceso a datos sensibles	NO REGISTRADO	Sin access log
Eliminación de candidato	PARCIAL Solo elimina el registro (destruye evidencia)	DB
Cambios en aviso de privacidad	PARCIAL <code>CompanyPrivacyNotice.version</code> pero sin historial — overwrite	DB

Estado: IMPLEMENTADO PARCIALMENTE — trazabilidad limitada a consentimiento y timestamps. **No existe bitácora de acceso, no existe auditoría de decisiones, no existe historial de versiones del aviso.**

RESPONSABILIDAD

Responsabilidad que actualmente asume la EMPRESA CONTRATANTE (Responsable)

Conforme al aviso de privacidad (`privacy-notice.ts:174, 199-205`) y la arquitectura:

1. **Definir el puesto y categoría** — La empresa crea el `Position` con `title` , `sector` , `category` . EvaluHR solo ofrece categorías predefinidas, no propone criterios.

2. **Invitar candidatos** — Solo RH/SA de la empresa emite invitaciones (`/api/invite` POST).
3. **TOMAR LA DECISIÓN FINAL DE CONTRATACIÓN** — El sistema **no tiene** botón “contratar”, no registra decisión, no envía comunicación de aceptación/rechazo. Todo ocurre fuera del sistema.
4. **Responder solicitudes ARCO** — Email `recursos.humanos@cafedechiapas.mx` es de la empresa. EvaluHR solo provee el texto del aviso.
5. **Cumplir con NOM-035-STPS-2018** — El aviso la menciona pero la responsabilidad legal es de la empresa.

Responsabilidad que actualmente podría asumir EVALUHR (Encargado)

Conforme al aviso (§12, `privacy-notice.ts:413-425`), EvaluHR se declara **Encargado** bajo Art. 12 LFPDPPP:

1. **Proveer infraestructura tecnológica** — Hosting, DB, autenticación, UI.
2. **Diseño de las pruebas** — **AQUÍ HAY RIESGO**: las 4 plantillas con sus ítems y fórmulas fueron creadas por EvaluHR (no por la empresa). Si una prueba es psicométricamente inválida o discrimina, EvaluHR podría ser considerado más que encargado.
3. **Cálculo de scores** — EvaluHR define las fórmulas (no la empresa). Si una fórmula produce sesgo discriminatorio, EvaluHR es responsable del algoritmo.
4. **Generación del `summary` textual** — EvaluHR redacta el texto orientativo que ve RH. Si el texto sugiere “excluir”, EvaluHR participa en la decisión.
5. **Hosting de datos sensibles** — EvaluHR (vía Supabase) almacena respuestas psicológicas y de integridad. Si hay breach, responsabilidad compartida.

Situaciones donde EVALUHR podría ser considerado MÁS QUE ENCARGADO

Situación	Razón	Riesgo
Diseño de pruebas psicométricas no validadas	EvaluHR creó items + fórmulas, no adaptó instrumentos validados. Si un candidato demandara por daño (p.ej. no contratado por “neuroticismo alto”), EvaluHR sería co-responsable del instrumento.	ALTO
Generación de recommendation	Aunque ahora es solo “orientación”, el campo se llama recommendation y RH lo ve. Si un candidato es excluido por PERFIL_PARCIAL, EvaluHR proveyó la categoría.	MEDIO
summary textual con sugerencias	El texto generado por generateSummary (route.ts:227-323) incluye frases como “fortalezas” y “áreas a explorar” que influyen en la decisión de RH.	MEDIO
Fabricación retroactiva de consentimiento	/api/consent/fix permite a RH crear evidencia falsa de consentimiento. EvaluHR proveyó la herramienta → complicidad técnica en violación Art. 8.	CRÍTICO
Decisiones automatizadas implícitas	A pesar del disclaimer “no decisiones automatizadas”, el overallScore y recommendation son outputs algorítmicos que RH puede usar como único criterio. Art. 37 Bis fr. IV requiere que el candidato pueda solicitar revisión humana — no existe endpoint para esto.	ALTO

Situaciones donde EvaluHR actúa como PROVEEDOR TECNOLÓGICO puro

- Hosting de la DB (vía Supabase)
- Autenticación JWT
- UI de administración
- UI de evaluación
- Cálculo mecánico de scores (cuando las fórmulas son neutrales)

Situaciones donde EvaluHR PARTICIPA EN LA DECISIÓN DE SELECCIÓN

- Cuando RH usa **overallScore** como filtro (aunque no haya **WHERE** automático, RH puede filtrar manualmente)

- Cuando RH usa `recommendation = PERFIL_COMPLETO` como shortlist
- Cuando RH lee el `summary` y se forma impresión

RIESGOS DERIVADOS DE QUE EVALUHR GENERE RECOMENDACIONES

Aunque el `recommendation` actual es solo orientación de completitud (no APTO/NO_APTO):

1. RH puede interpretarlo como recomendación real — el nombre del campo es `recommendation`.
2. No hay disclaimer visible en `CandidateDetailView` junto al campo — el disclaimer solo está en `summary` textual, no en el badge visual.
3. Si se reintrodujera APTO/NO_APTO (legacy en seed), EvaluHR pasaría a tomar decisión automatizada → Art. 37 Bis violación.

RIESGOS DERIVADOS DE QUE EVALUHR DETERMINE APTO/NO_APTO

Actualmente NO determina (eliminado del código). Pero el campo `recommendation` persiste con el nombre, y los datos semilla obsoletos (`APTO` , `NO_RECOMENDADO`) podrían confundir a un auditor.

RIESGOS DERIVADOS DE DECISIONES AUTOMATIZADAS

- `overallScore` es automático y se muestra a RH.
- No existe mecanismo para que el candidato solicite **revisión humana** del score (Art. 37 Bis fr. IV).
- No existe endpoint “dispute my score”.

RIESGOS DERIVADOS DE IA

No hay IA en producción → riesgo directo por IA = NINGUNO.

Riesgo indirecto: - Dependencia `z-ai-web-dev-sdk` instalada pero no usada → **capacidad técnica latente**. Si se activara sin actualizar el consentimiento y aviso, sería violación Art. 8 (consentimiento no informado para nuevo tratamiento). - Documentación `PROJECT_STATUS.md` menciona funcionalidad IA que no existe → si un auditor la lee, podría asumir que sí funciona.

RIESGOS CRÍTICOS

#	Riesgo	Severidad	Estado código
R1	Fabricación retroactiva de consentimiento (<code>/api/consent/fix</code>) — violación LFPDPPP Art. 8	CRÍTICO	IMPLEMENTADO (funciona)
R2	Option B no se cumple server-side — candidato con consent “solo conocimientos” puede vía API responder items sensibles que se almacenan	CRÍTICO	NO IMPLEMENTADO server-side
R3	Revocación miente — UI promete eliminación, API no elimina nada	CRÍTICO	IMPLEMENTADO PARCIALMENTE
R4	Aviso de privacidad describe comportamientos que el código no cumple (eliminación al concluir, cifrado en reposo, Option B no recopila sensible, IP 90 días)	CRÍTICO	NO IMPLEMENTADO
R5	Credenciales hardcodeadas en git (service_role JWT, DB password, JWT_SECRET fallback)	CRÍTICO	EXPOSICIÓN
R6	Derechos ARCO no implementados como workflow — solo textuales	CRÍTICO	NO IMPLEMENTADO
R7	Pruebas psicométricas no validadas — items originales sin baremo, sin fiabilidad documentada, 2 items/dimensión insuficiente	CRÍTICO	NO IMPLEMENTADO (validación)
R8	Items de integridad elicitán auto-incriminación de robo — pueden constituir datos sensibles adicionales	ALTO	IMPLEMENTADO
R9	DB-level RLS no aplicado — solo app-level, 41 bypasses vía <code>getUnscopedClient()</code>	ALTO	IMPLEMENTADO PARCIALMENTE
R10	<code>/api/health</code> público expone email SUPER_ADMIN + prefijo JWT_SECRET + conteos	ALTO	NO IMPLEMENTADO (mitigación)
R11	<code>/api/cleanup</code> destrucción multi-tenant irreversible sin auditoría ni confirmación	ALTO	IMPLEMENTADO (peligroso)
R12	Token JWT en localStorage — derrota httpOnly, habilita robo por XSS	ALTO	NO IMPLEMENTADO (mitigación)
R13	Stored XSS vía <code>CompanyPrivacyNotice.contentHtml</code> sin sanitización	ALTO	NO IMPLEMENTADO (mitigación)
R14	Sin rate limiting — brute-force en <code>/api/auth</code> y enumeración de tokens	ALTO	NO IMPLEMENTADO
R15	Sin account lockout — unlimited password attempts	ALTO	NO IMPLEMENTADO
R16	Sin security headers (HSTS, CSP, X-Frame-Options)	ALTO	NO IMPLEMENTADO
R17	Escalación horizontal candidato → candidato vía <code>/api/results?resultId=</code>	MEDIO	IMPLEMENTADO PARCIALMENTE
R18		ALTO	IMPLEMENTADO PARCIALMENTE

#	Riesgo	Severidad	Estado código
	/api/users PUT sin verificar cross-tenant para RH		
R19	Auto-login muta companyId si mismatch — token replay cross-tenant	MEDIO	IMPLEMENTADO PARCIALMENTE
R20	No hay registro de decisión final de contratación — imposibilidad de auditoría de decisiones laborales	MEDIO	NO IMPLEMENTADO
R21	No hay re-consentimiento al cambiar versión del aviso	MEDIO	NO IMPLEMENTADO
R22	ConsentLog sin userAgent ni hash del aviso — evidencia incompleta	MEDIO	IMPLEMENTADO PARCIALMENTE
R23	Version mismatch (v1 en código vs v2 en schema default)	BAJO	IMPLEMENTADO PARCIALMENTE
R24	Datos semilla obsoletos (APTO / NO_RECOMENDADO en seed.ts) pueden confundir auditoría	BAJO	IMPLEMENTADO PARCIALMENTE
R25	Email inconsistente entre UI (recursos.humanos@cafedechiapas.mx) y aviso dinámico (rrhh@<slug>.com)	BAJO	IMPLEMENTADO PARCIALMENTE
R26	Transferencia internacional no declarada (Supabase Canada, Vercel) — aviso dice “no transferencias”	MEDIO	IMPLEMENTADO PARCIALMENTE
R27	Option C (estadísticas anónimas) no anonimiza — solo checkbox vacío	MEDIO	NO IMPLEMENTADO
R28	Eliminación de candidato destruye ConsentLog — viola Art. 88 Reglamento	MEDIO	IMPLEMENTADO (incorrecto)

CAMBIOS RECOMENDADOS

No implementados. Solo enumeración para revisión jurídica.

CRÍTICOS (bloqueantes para producción legal)

1. Eliminar **/api/consent/fix** — fabricación retroactiva de consentimiento es ilegal (LFPDPPP Art. 8).
2. Implementar server-side enforcement de **Option B** — **/api/evaluations** POST debe verificar **consentOption** antes de aceptar respuestas a ítems sensibles.
3. Implementar eliminación real al retirar consentimiento — ya sea inmediata o vía job programado, pero la UI no debe prometer lo que no se cumple.
4. Alinear aviso de privacidad con la realidad técnica — eliminar claims falsos (cifrado en reposo, eliminación al concluir, IP 90 días) o implementarlos.

5. **Rotar credenciales expuestas** — service_role JWT, DB password, JWT_SECRET fallback. Mover todo a env vars con fail-closed.
6. **Implementar endpoints ARCO** — al menos `GET /api/arco/access` (auto-servicio candidato), `DELETE /api/arco/cancellation`, con workflow admin y SLA tracking.
7. **Reemplazar pruebas con instrumentos validados** (IPIP-NEO short form es público) o añadir disclaimer explícito de “no es instrumento validado” + comisión de estudio de validez.
8. **Eliminar items 7-8 de INTEGRIDAD** (auto-incriminación de robo) o someterlos a revisión legal específica.

ALTOS

1. Aplicar `prisma/rls-policies.sql` + crear rol Postgres no-superuser + `FORCE ROW LEVEL SECURITY`.
2. Remover `/api/health` de rutas públicas o sanitizar output (no exponer email admin, prefijo JWT_SECRET).
3. Eliminar o hard-gate `/api/cleanup` (worklog ya lo marca como “temporal”).
4. Eliminar token de localStorage — usar cookie-only.
5. Sanitizar `CompanyPrivacyNotice.contentHtml` con `isomorphic-dompurify` o `sanitize-html`.
6. Agregar rate limiting (`rate-limiter-flexible`) en `/api/auth` y `/api/public/invitation`.
7. Agregar account lockout (`failedAttempts` + `lockedUntil` en `User`).
8. Agregar password reset flow con token time-limited.
9. Agregar security headers (HSTS, CSP, X-Frame-Options) en `next.config.ts`.
10. Agregar `candidateId` ownership check en `/api/results?resultId=`.
11. Agregar `companyId` cross-tenant check en `/api/users` PUT para RH.
12. Implementar re-consentimiento al cambiar versión del aviso.
13. Capturar `userAgent` y hash del aviso en `ConsentLog`.

MEDIOS

1. Implementar Option C (pipeline real de anonimización) o eliminar el checkbox.
2. Agregar `AuditLog` table para SUPER_ADMIN impersonation, cleanup, migrate, consent admin actions.
3. Implementar mecanismo de revisión humana solicitable por candidato (Art. 37 Bis fr. IV).
4. Agregar `decisionById`, `decisionAt`, `decisionReason` a `EvaluationResult` o tabla separada, para registrar decisión final.
5. Declarar transferencias internacionales (Supabase Canada, Vercel) en aviso.
6. Unificar email de contacto entre UI y aviso dinámico.
7. No destruir `ConsentLog` al eliminar candidato — retener evidencia (Art. 88 Reglamento).
8. Reconciliar item sets entre `seed.ts`, `seed-supabase.ts`, `generate-templates.ts`.
9. Limpiar datos semilla obsoletos (`APTO` / `NO_RECOMENDADO`).

BAJOS

1. Eliminar dependencia `z-ai-web-dev-sdk` del `package.json` (no se usa).
2. Actualizar `PROJECT_STATUS.md` para remover referencias a funcionalidad IA inexistente.
3. Unificar versiones de consentimiento (`v1` vs `v2`).
4. Agregar botón “No consiento” en `ConsentView` con salida graceful.

INFORMACIÓN QUE NO PUEDES DETERMINAR

#	Item no determinable	Razón	Qué se necesitaría revisar
1	Configuración real de <code>JWT_SECRET</code> en producción Vercel	Variables env no están en el repo	Acceso al dashboard Vercel
2	Si <code>prisma/rls-policies.sql</code> fue aplicado manualmente a la DB	El código no lo ejecuta, pero alguien podría haberlo corrido manualmente	Conexión directa a Supabase + <code>SELECT * FROM pg_policies</code>
3	Rol Postgres real de la conexión Prisma en prod	<code>.env.example</code> sugiere <code>postgres</code> user pero <code>.env</code> real no está en repo	Verificar <code>DATABASE_URL</code> en Vercel env vars
4	Versión del PDF estático <code>/public/Aviso_de_Privacidad_Consentimiento_EvaluHR.pdf</code>	No se puede verificar contenido programáticamente	Abrir el PDF manualmente
5	Si <code>CompanyPrivacyNotice.contentHtml</code> está siendo inyectado con scripts por usuarios RH	Depende de datos runtime	Auditar registros en prod DB
6	Política real de backups de Supabase	Gestionado por Supabase, no por la app	Dashboard Supabase
7	Configuración de retención de logs de Vercel	Gestionado por Vercel	Dashboard Vercel
8	Términos contractuales Supabase/Vercel con el cliente	Fuera del repo	Contratos
9	Si la migración de <code>Position.status</code> (worklog Task ID 1) fue la única ejecutada en prod o si hubo otras	<code>/api/migrate</code> es idempotente pero no auditable	Logs de Supabase
10	Versión de consentimiento realmente almacenada para usuarios existentes en prod	Depende de cuándo se registraron	<code>SELECT consentVersion, COUNT(*) FROM User GROUP BY consentVersion</code>
11	Si el campo <code>VacancyApplication.videoUrl</code> fue usado en algún momento y luego desactivado	El código actual no lo usa pero el schema lo tiene	Git history / migraciones anteriores
12	Si existe algún job cron externo (Vercel Cron, Supabase Edge Function) que ejecute limpieza	No hay <code>vercel.json</code> con cron, pero podría configurarse externamente	Dashboard Vercel/Supabase
13	Si los items de las pruebas fueron revisados por un psicólogo certificado	No hay documentación de eso en el repo	Documentación externa / proceso de diseño
14	Si la empresa "Café de Chiapas" es el único cliente real o hay otros en prod	Depende de datos runtime	<code>SELECT COUNT(*) FROM Company</code>

#	Item no determinable	Razón	Qué se necesitaría revisar
15	Si las transferencias internacionales a Canada/USA tienen cláusulas contractuales estándar (SCC)	Fuera del código	Contratos Supabase/Vercel
16	Compliance real con NOM-035-STPS-2018 (la app la menciona pero no es una herramienta NOM-035)	Fuera del código	Documentación legal externa
17	Si existe un DPO (Data Protection Officer) designado	Fuera del código	Documentación organizacional
18	Si el contacto <code>recursos.humanos@cafedechiapas.mx</code> está activo y monitoreado	Fuera del código	Verificación con la empresa

FIN DE LA AUDITORÍA.

Esta auditoría se basa exclusivamente en evidencia del código fuente en `/home/z/my-project` (commit `1249353` al momento de la revisión). Ninguna afirmación es especulativa. Toda declaración de estado está respaldada por archivo y línea citable en los reportes de los 6 agentes de exploración. La respuesta está lista para ser entregada al sistema de IA especializado en análisis jurídico bajo legislación mexicana (LFPDPPP, NOM-035-STPS-2018, Art. 37 Bis).